Written assignment (Exam)

Module: GRC1100-1 23H

Release date of the assignment: 22/11/2023 10:00

Due date for submission: 06/12/2023 10:00

Module leader and e-mail: Toktam Ramezanifarkhani | Toktam.Ramezanifarkhani@kristiania.no

The assignment set has three pages.

There is a 14-day deadline for this home exam. Please note that the exam MUST be submitted within the deadline and via the exam platform WISEFLOW. It will not be possible to submit the assignment after the deadline - this means that you should submit it in good time to contact the exam office or user support if you have technical problems.

As this is a home exam, it is important to show a holistic understanding, and the assignments have more focus on discussion. Therefore, complete and explanatory answers to all assignments are expected. You can choose to draw figures and sketches in a Word document or draw on paper and upload a picture. You can use any tool, take screenshots and insert them as well. Remember to insert the image in the right place in the answer. (Otherwise, they are not considered a part of the answer.)

The student should answer the exam independently and individually. Cooperation between students is not allowed. Plagiarism will be checked. So all the sentences should be yours and reflect your understanding. All text, pictures, and illustrations taken from lectures, textbooks, or the internet must have a reference. You can choose any Referencing style.

NOTE: The answer should be at most 15 A4 pages, with a font size 12, standard margins, and a line spacing 1.0.

NOTE: You can answer the questions in English (if you don't have a possibility of answering in English, Norwegian Bokmål is the second option).

If you should become ill or encounter other problems, make sure that you contact eksamen@kristiania.no before the deadline. They will advise you on what to do.

Submission is a PDF file upload.

To explain your answers and discuss and give examples, choose a use case such as a workplace, company, start-up, organization, university, etc., or a fictional one, if necessary. Answer the questions and discuss your answers.

Question 1. Risk Management

1. Model and explain a system with a scenario. You can use STS modeling. Explain all the elements of the system and their communication. (Hint: You can choose student activities through a web application, such as the registration process at a university. You can work on a risk of possible Network Sniff.)
2. Extract security requirements (at least three) and threats (at least two). Explain your answer.
3. How do we calculate the risk based on likelihood and impact? Explain your answer by calculating the risks of your system in OWASP. Prioritize your extracted risks. (Hint: estimate the risk levels and sort them to prioritize and explain your answer.)
4. Explain environmental metrics in the CVSS Calculator and the different factors used to estimate risks. Give examples of how they affect your system/use case risk.
5. What are the possible risk treatments for the risks? Select one defense mechanism as a risk treatment for your identified risks and estimate the residual risks after applying the defense mechanisms.

Question 2. Governance

1. What are the ‘Overconfidence bias’, and ‘illusion of control’ in risk management in your use case? How might these be a problem for risk management? What strategies might you use to help avoid these biases?
2. Explain risk and risk management. What is the difference between security management and security governance? Give examples in your use case.
3. What is the organizational maturity level? Explain how you can increase the capability maturity model integration (CMMI) in your use case with at least three factors/attributes of CMMI.

Question 3. Compliance

1. Name two primary standards related to security risk management frameworks and governance that can be used in your use case and describe them briefly.
2. Explain Business Continuity Management (BCM) and Disaster Recovery Planning (DRP) in your use case. Who is responsible to do these tasks?
3. Explain three categories of security controls you can apply to control and manage risks. Give an example of their application to reduce risks in your system.

Assignment criteria*

Grade	Knowledge	Skills	Competence
A Excellent	Excellent and comprehensive understanding of theory	Demonstrates excellent analytical, technical and writing skills	Outstanding degree of judgment and independent thinking
B Very good	Very good understanding of theory	Demonstrates very good analytical, technical and writing skills	Sound degree of judgment and independent thinking
C Good	Good understanding of theory in most important areas	Demonstrates good analytical, technical and writing skills	Reasonable degree of judgment and independent thinking
D Satisfactory	Satisfactory understanding of theory, but with significant shortcomings	Demonstrates sufficient analytical, technical and writing skills	Limited degree of judgment and independent thinking
E limited	Meets the minimum understanding of theory	Demonstrates limited analytical, technical and writing skills	Very limited degree of judgment and independent thinking
F Fail	Fail to meet the minimum academic criteria	No demonstration of analytical, technical and writing skills	Absence of judgment and independent thinking

*Adapted from The Norwegian Association of Higher Education Institutions

Grading

The assignment is worth 100% of the course grade, and all the sub-questions have the same weight.